Conditional Access Rollout Checklist

Use this before, during and after any new Conditional Access policy. Work top to bottom. Tick each box in the printed copy.

1. Before you create anything

Check	Done	Notes
Written goal: who, which apps, which risk is reduced	☐	
At least two emergency access accounts exist and are excluded from policies. Confirm they work and are monitored.	☐	See Learn: Manage emergency access accounts in Microsoft Entra ID
Pilot group chosen (small, includes a helpdesk contact)	☐	
Legacy authentication and service accounts identified (scripts, mailboxes, devices)	☐	Policies can block these silently
Rollback owner and change window agreed	☐	

2. Build in report-only mode

Create the policy with Report-only enabled. Do not switch it to On until the review in step 3 is complete.

Item	Done
Policy name follows your convention and states the purpose	☐
Users and groups: pilot group only (not All users)	☐
Cloud apps and conditions set explicitly (no accidental 'All cloud apps' unless intended)	☐
Grant control set; session controls reviewed	☐

3. Review the report-only results

Use the Conditional Access insights and reporting view and the sign-in logs. Look for failures that would have been blocked, not only successful sign-ins.

Scenario to test	Result	Done
Browser sign-in to Microsoft 365 web apps		☐
Outlook desktop and mobile (modern auth)		☐
Teams desktop and mobile		☐
Admin portals, PowerShell and Graph scripts used by admins		☐
Guest or external users, if in scope		☐
Devices not yet registered or compliant (if the policy needs them)		☐

4. Staged enablement

Stage	Scope	Wait before next stage	Done
1. Pilot	Pilot group, On	Agreed period (for example several days), no open helpdesk pattern	☐
2. Department	One department	Review sign-in failures and tickets	☐
3. Wider scope	All users except exclusions	Monitor for one full working cycle	☐

5. Failure scenarios and rollback

If you see	Check first	Action
Many users blocked at once	Policy scope, exclusions, recent change	Set the policy to Off (do not delete it) and record the time
One app stops working	App registration, service account, legacy auth	Exclude only that identity, with an expiry date and an owner
Admins locked out	Break-glass accounts still excluded?	Use an emergency account; disable the policy

6. Monitoring after go-live

Check	Frequency	Done
Sign-in logs filtered by Conditional Access result (failure and report-only)	Daily for the first week	☐
Exclusion list reviewed: owner, reason, expiry date	Monthly	☐
Policy change logged in your change record	Each change	☐

Sign-off: name, date, policy ID, final state (Report-only / On / Off). _____